Mandate API Contract (v3)

The agreement between the backend (Tech Lead) and the frontend (Frontend Developer). **The frontend can build every screen today using the example responses below as mock data**, then switch to the real API as each endpoint goes live.

> Status: ✅ live · 🛠 planned (target date). If you need a change, ask the Tech Lead; don't work around it. Changes are noted in the changelog at the bottom.

Conventions

Topic	Rule
Base URL	`/api` (dev: the frontend proxies `/api` to `http://localhost:4000`)
Format	JSON in, JSON out (except SSE streams and file upload)
Money	Always **integer cents**: `balanceCents: 184050` = **$1,840.50**. Format on the frontend: `(cents / 100).toLocaleString("en-US", { style: "currency", currency: "USD" })`
Dates	`"2026-10-12"` (date) or `"2026-10-12T09:15:00.000Z"` (timestamp, UTC)
Persona	Most routes start with `/api/personas/:personaId/...` (`maya`, `daniel`, `aisha`)
Auth (from Oct 15)	Sign in with `POST /api/auth/login`; the server sets an `HttpOnly` session cookie that the browser sends automatically (same origin through the proxy; with `fetch`, use `credentials: "include"` if you ever call the API from another origin). **Every** `/api/personas/:personaId/*`, `/api/wishes/*` and `/api/actions/*` route needs it: not signed in → `401`; another persona's data → `403`. Public: `/api/health`, `/api/meta`, `/api/personas`, `/api/auth/*`
PIN (from Oct 15)	Three risky actions need the persona's 4-digit `pin` in the request body: **approving** an action, **signing** a mandate, turning the agent **on**. Wrong PIN → `403` with `attemptsLeft`; 5 failures → `429` with `retryAfterSeconds`
Errors	Non-2xx responses always return `{ "error": "message", "issues"?: [...], "attemptsLeft"?: n, "retryAfterSeconds"?: n }`
Types	TypeScript types for every shape live in `packages/shared` (`@mandate/shared`) and can be imported directly by the frontend

Shared value lists

- `AccountType`: `checking` · `savings` · `credit`
- `Category`: `income` · `housing` · `utilities` · `groceries` · `dining` · `transport` · `subscriptions` · `shopping` · `education` · `health` · `entertainment` · `transfer` · `fees` · `other`
- `Tier`: `L0` observe · `L1` recommend · `L2` act with approval · `L3` autonomous
- `Decision`: `allow` · `require_approval` · `deny`
- `ActionStatus`: `executed` · `pending_approval` · `denied` · `rejected`
- `ActionSource`: `user` · `agent` · `untrusted`
- `PayCadence`: `daily` · `weekly` · `biweekly` · `monthly` · `irregular`

- `WishCategory`: `gadget` · `vehicle` · `property` · `travel` · `education` · `luxury` · `other`
- `WishStatus`: `on_track` · `tight` · `not_realistic` · `achieved` · `paused`

> **Data resets on restart.** The backend keeps data in memory, loaded from CSV files. Restarting the server (or `POST /api/admin/reset`) restores the original demo data. The hosted version is kept awake by a pinger, but if it ever does sleep, the first request can take about a minute, so show a friendly loading state.

System

✅ `GET /api/health` (also `HEAD`)

Used by the keep-alive pinger (`HEAD`) and the frontend's waking-up check (`GET`).

```
{ "ok": true, "service": "mandate-api", "time": "2026-10-12T15:27:27.423Z" }
```

✅ `GET /api/meta`

```
{ "tiers": ["L0", "L1", "L2", "L3"] }
```

✅ `POST /api/admin/reset`

Reloads all demo data from the CSV seed files (also clears sign-in lockouts). From Oct 15 it needs the header `x-admin-key: <ADMIN_KEY>` when `ADMIN_KEY` is set on the server (always on the hosted version; open in local dev). Returns `{ "ok": true, "resetAt": "2026-10-13T10:00:00.000Z" }`. Use it from a hidden "Reset demo" button.

Auth (Oct 15)

🛠 `GET /api/auth/demo-accounts`

Public list for the sign-in screen. The credentials are fake and intentionally public; showing them lets judges sign in with one click.

```
[
  { "personaId": "maya", "name": "Maya Chen", "profile": "International student…",
"username": "maya", "password": "maya-demo", "pin": "1111" }
]
```

🛠 `POST /api/auth/login`

Request: `{ "username": "maya", "password": "maya-demo" }` → `200` with the `Persona` and a `Set-Cookie` header. Wrong credentials → `401 { "error": "Wrong username or password", "attemptsLeft": 4 }`. Locked → `429 { "error": "Too many attempts", "retryAfterSeconds": 300 }`.

🛠 `GET /api/auth/me`

→ `{ "persona": Persona }` when signed in, `401` otherwise. Call it on app start to decide between the sign-in screen and the app.

🛠 `POST /api/auth/logout`

→ `204`, clears the cookie. "Switch demo account" = logout + login as another persona.

Bank data

✅ `GET /api/personas`

```
[
  { "id": "maya", "name": "Maya Chen", "profile": "International student, part-time cafe job", "currency": "USD" },
  { "id": "daniel", "name": "Daniel Okafor", "profile": "Young professional, many subscriptions", "currency": "USD" },
  { "id": "aisha", "name": "Aisha Rahman", "profile": "Gig worker with weekly income", "currency": "USD" }
]
```

✅ `GET /api/personas/:personaId/accounts`

```
[
  { "id": "acc_maya_chk", "personaId": "maya", "type": "checking", "name": "Everyday checking", "balanceCents": 64210 },
  { "id": "acc_maya_sav", "personaId": "maya", "type": "savings", "name": "Savings", "balanceCents": 35000 }
]
```

✅ `GET /api/personas/:personaId/transactions`

Query (all optional): `from`, `to` (dates), `category`, `account` (AccountType), `limit` (default 50, max 500), `offset`. Sorted newest first. Invalid values → `400` with `issues`. Response type: `TransactionPage` from `@mandate/shared`.

```
{
  "total": 214,
  "items": [
    {
      "id": "tx_8f2a",
      "accountId": "acc_maya_chk",
      "date": "2026-10-09",
      "description": "Weekly pay",
      "merchant": "Campus Cafe Payroll",
      "amountCents": 24550,
      "category": "income",
      "memo": null
    }
  ]
}
```


✅ **`GET /api/personas/:personaId/budget`**

Current month by default; `?month=2026-09` for another (invalid → `400`). Each category's budget = average of the last 3 full months (one-off payments over $500 excluded), rounded up to $5. `spentCents` = this month so far. `insights` are ready-to-show sentences. Real example (Maya):

```
{
  "month": "2026-10",
  "safeToSpendTodayCents": 3445,
  "categories": [
    {
      "category": "housing",
      "budgetCents": 75000,
      "spentCents": 75000
    },
    {
      "category": "groceries",
      "budgetCents": 39500,
      "spentCents": 5306
    },
    {
      "category": "dining",
      "budgetCents": 17500,
      "spentCents": 7785
    },
    {
      "category": "shopping",
      "budgetCents": 10500,
      "spentCents": 9135
    },
    {
      "category": "utilities",
      "budgetCents": 8000,
      "spentCents": 0
    },
    {
      "category": "subscriptions",
      "budgetCents": 6000,
      "spentCents": 5747
    },
    {
      "category": "transport",
      "budgetCents": 6000,
      "spentCents": 6000
    }
  ],
  "insights": [
    "Dining is ahead of pace: $77.85 of $175 spent already.",
    "Shopping is ahead of pace: $91.35 of $105 spent already.",
    "You haven't used FitZone since you started paying (163 days). It costs $29.99 a month."
  ]
}
```


`safeToSpendTodayCents`: the most she can spend per day from today without her planned checking balance (pay + bills + commitments, next 30 days) ever dropping below $200.

✅ **`GET /api/personas/:personaId/forecast`**

30 days of projected checking balance, starting today, including typical everyday spending. Real example (Maya, first 3 of 30 days shown):

```
{
  "days": [
    {
      "date": "2026-10-12",
      "balanceCents": 45233
    },
    {
      "date": "2026-10-13",
      "balanceCents": 43074
    },
    {
      "date": "2026-10-14",
      "balanceCents": 40915
    }
  ],
  "lowestPoint": {
    "date": "2026-10-15",
    "balanceCents": 38756
  },
  "warnings": []
}
```


`warnings` is empty when the balance stays above $200; otherwise e.g. `"Checking may drop below $200 on Nov 1 after Greenview Student Housing ($750)."`

✅ `GET /api/personas/:personaId/subscriptions`

Sorted by `unusedDays` (least used first). `lastUsed: null` + a number in `unusedDays` = never used since the first charge; `unusedDays: null` = no usage data. Real example (Maya):

```
[
  {
    "id": "sub_maya_fitzone",
    "merchant": "FitZone",
    "amountCents": 2999,
    "cadence": "monthly",
    "accountId": "acc_maya_chk",
    "lastCharged": "2026-10-02",
    "nextCharge": "2026-11-02",
    "lastUsed": null,
    "unusedDays": 163,
    "status": "active"
  },
  {
    "id": "sub_maya_netflix",
    "merchant": "Netflix",
    "amountCents": 1549,
    "cadence": "monthly",
    "accountId": "acc_maya_chk",
    "lastCharged": "2026-10-09",
    "nextCharge": "2026-11-09",
    "lastUsed": "2026-10-09",
    "unusedDays": 3,
    "status": "active"
  },
  {
    "id": "sub_maya_spotify",
    "merchant": "Spotify",
    "amountCents": 1199,
    "cadence": "monthly",
    "accountId": "acc_maya_chk",
    "lastCharged": "2026-10-05",
    "nextCharge": "2026-11-05",
    "lastUsed": "2026-10-11",
    "unusedDays": 1,
    "status": "active"
  }
]
```


✅ `GET /api/personas/:personaId/bills`

Predicted bills due in the next 30 days, soonest first. Real example (Maya):

```
[
  {
    "id": "bill_maya_mobi-telecom_20261012",
    "payee": "Mobi Telecom",
    "amountCents": 3500,
    "dueDate": "2026-10-12",
    "status": "due",
    "source": "bank",
    "accountId": "acc_maya_chk"
  },
  {
    "id": "bill_maya_greenview-utilities_20261020",
    "payee": "Greenview Utilities",
    "amountCents": 4251,
    "dueDate": "2026-10-20",
    "status": "due",
    "source": "bank",
    "accountId": "acc_maya_chk"
  },
  {
    "id": "bill_maya_greenview-student-housing_20261101",
    "payee": "Greenview Student Housing",
    "amountCents": 75000,
    "dueDate": "2026-11-01",
    "status": "due",
    "source": "bank",
    "accountId": "acc_maya_chk"
  },
  {
    "id": "bill_maya_city-transit_20261101",
    "payee": "City Transit",
    "amountCents": 6000,
    "dueDate": "2026-11-01",
    "status": "due",
    "source": "bank",
    "accountId": "acc_maya_chk"
  }
]
```


`status`: `due` · `paid` · `overdue`. `source`: `bank` (predicted from history) or `document` (uploaded PDF, from Oct 17).

✅ **`GET /api/personas/:personaId/pay-cycle`**

Detected from income history. `payday` is a ready-to-show label: `"Fridays"`, `"the 25th"`, `"almost every day"`. Real example (Maya):


```
{
  "cadence": "weekly",
  "payday": "Fridays",
  "nextPayday": "2026-10-16",
  "avgIncomePerCycleCents": 41611,
  "avgSurplusPerCycleCents": 4706
}
```

`avgSurplusPerCycleCents` = what's typically left each pay cycle after **all** normal spending (one-offs and savings transfers excluded). Wish plans are checked against it. For daily earners (Aisha) everything is per day.

Wishes

The `Wish` object

```
{
  "id": "wish_maya_iphone",
  "personaId": "maya",
  "title": "iPhone 17",
  "category": "gadget",
  "targetCents": 120000,
  "savedCents": 15000,
  "targetDate": "2027-04-12",
  "priority": 1,
  "autoSave": true,
  "status": "tight",
  "progressPct": 12.5,
  "plan": {
    "cadence": "weekly",
    "perPaydayCents": 4620,
    "paydaysLeft": 26,
    "nextContributionDate": "2026-10-16"
  },
  "eta": { "date": "2027-04-09", "daysVsTarget": -3 },
  "advice": [
    "Saving $46.20 each Friday uses 62% of what you usually have left over.",
    "Cut dining by $10 a week to make this comfortable."
  ],
  "createdAt": "2026-10-12T09:00:00.000Z"
}
```

- `eta.daysVsTarget`: negative = early, positive = late, `null` if it can't be reached at the current pace.
- `status`: `on_track` (comfortable), `tight` (doable but uses most of the surplus), `not_realistic` (needs more than the surplus), `achieved`, `paused`.

🛠 `GET /api/personas/:personaId/wishes` (Oct 14)

Returns `Wish[]`, sorted by `priority`, plus a summary:

```
{
  "wishes": [ { "...": "Wish" } ],
  "totalPerPaydayCents": 6620,
  "surplusPerPaydayCents": 7450,
  "overCommitted": false
}
```

🛠 `POST /api/personas/:personaId/wishes/preview` (Oct 14)

Live plan calculator for the "new wish" form. **Doesn't save anything.** Call it as the user types (debounce ~300 ms). Request:

```
{ "title": "iPhone 17", "category": "gadget", "targetCents": 120000, "targetDate": "2027-04-12", "savedCents": 0 }
```

Response: a `Wish` object without `id` / `createdAt`.

🛠 `POST /api/personas/:personaId/wishes` (Oct 14)

Same body as preview, plus optional `"priority": 2` and `"autoSave": true` → returns the saved `Wish` (201).

🛠 `GET /api/wishes/:wishId` (Oct 14)

The `Wish`, plus its history:

```
{
  "wish": { "...": "Wish" },
  "contributions": [
    { "id": "wc_1", "date": "2026-10-09", "amountCents": 4620, "source": "agent", "actionId": "act_77aa" }
  ],
  "projection": [
    { "date": "2026-10-16", "savedCents": 19620 },
    { "date": "2026-10-23", "savedCents": 24240 }
  ]
}
```

`projection` is the expected savings curve for a progress chart (one point per payday).

🛠 `PATCH /api/wishes/:wishId` (Oct 14)

Any of: `title`, `targetCents`, `targetDate`, `priority`, `autoSave`, `paused` → returns the updated `Wish` with a recalculated plan.

🛠 `DELETE /api/wishes/:wishId` (Oct 14)

Removes the wish. Money already saved stays in savings. Returns `204`.

🛠 `POST /api/wishes/:wishId/contribute` (Oct 15)

Manual top-up from checking to savings. Request: `{ "amountCents": 2000 }` → returns an `Action` (it goes through the policy engine like everything else, so it can be `executed`, `pending_approval` or `denied`).

🛠 `GET /api/personas/:personaId/wishes/impact?amountCents=6000` (Oct 15)

"What does this purchase do to my wishes?"

```
{
  "amountCents": 6000,
  "impacts": [
    { "wishId": "wish_maya_iphone", "title": "iPhone 17", "delayDays": 9 }
  ],
  "message": "Buying this delays your iPhone 17 by 9 days."
}
```

Also included automatically in payment `Action`s as `wishImpact` (same shape as `impacts`).

Agent & actions

🛠 `POST /api/personas/:personaId/chat` (Oct 15): Server-Sent Events stream

Request: `{ "message": "Can I afford a $60 concert ticket this week?" }` The response is a stream of events (read with `fetch` + a stream reader):

```
event: text      data: {"delta":"Yes. Your safe-to-spend today is $23.50, but "}
event: tool      data: {"name":"get_forecast","status":"done"}
event: action    data: { ...Action (see below) }
event: done      data: {}
event: error     data: {"error":"..."}
```

`text` arrives in small pieces; append each `delta` to the chat bubble.

The `Action` object (used by chat, approvals and the timeline)

```
{
  "id": "act_31c9",
  "personaId": "daniel",
  "type": "payment",
  "summary": "Pay CityPower $180.00 (power bill due Oct 16)",
  "params": { "payeeId": "payee_citypower", "amountCents": 18000, "fromAccount": "checking"
},
  "source": "agent",
  "tier": "L2",
  "decision": "require_approval",
  "status": "pending_approval",
  "reasons": ["Amount is over your $100 approval limit."],
  "agentRationale": "The bill is due in 4 days and checking can cover it.",
  "wishImpact": [{ "wishId": "wish_daniel_car", "title": "Car down payment", "delayDays": 4
}],
  "createdAt": "2026-10-12T09:15:00.000Z"
}
```

`type`: `payment` · `transfer` · `cancel_subscription` · `dispute` · `wish_contribution` `wishImpact` is present on payments (empty array if no wishes are affected). For `wish_contribution`, `params` includes `wishId`.

🛠 `GET /api/personas/:personaId/approvals` (Oct 15)

Returns `Action[]` with `status: "pending_approval"`.

🛠 `POST /api/actions/:actionId/decision` (Oct 15)

Request: `{ "decision": "approve", "pin": "1111" }` or `{ "decision": "reject" }` (rejecting never needs a PIN) → returns the updated `Action`. Approved actions record who approved them (`approvedBy`, `approvedAt`).

🛠 `GET /api/personas/:personaId/actions` (Oct 15)

All actions, newest first (`?limit=50`). For the action timeline's history.

🛠 `GET /api/personas/:personaId/timeline` (Oct 16): SSE stream

Pushes `event: action` with an `Action` whenever one is created or changes status. Use it to update the timeline and approvals badge live.

🛠 `POST /api/personas/:personaId/agent/run` (Oct 17)

Request: `{ "trigger": "payday" }` → `{ "actions": Action[] }`. Powers the "Run payday" demo button.

🛠 `POST /api/personas/:personaId/killswitch` (Oct 17)

Request: `{ "enabled": true }` → `{ "enabled": true }`. While enabled, the agent is limited to L0 (observe only). Turning the agent back **on** (`{ "enabled": false, "pin": "1111" }`) needs the PIN; stopping it never does. `GET` returns the current state.

Mandate (user rules)

🛠 `GET /api/personas/:personaId/mandate` (Oct 16)

```
{
  "version": 3,
  "naturalLanguage": "Never let checking drop below $200. Ask me before any payment over
$100 or to anyone new.",
  "signedAt": "2026-10-15T09:12:00.000Z",
  "policy": {
    "defaultTier": "L2",
    "rules": [
      { "type": "balance_floor", "account": "checking", "minCents": 20000 },
      { "type": "amount_cap", "perTxCents": 10000, "aboveTier": "L2" },
      { "type": "new_payee", "tier": "L2", "cooldownHours": 24 },
      { "type": "daily_cap", "maxCents": 50000 }
    ]
  },
  "summary": [
    "Checking never goes below $200.00.",
    "Payments over $100.00 need your approval.",
    "New payees need your approval and a 24-hour wait.",
    "The agent can move at most $500.00 per day."
  ]
}
```

🛠 `POST /api/personas/:personaId/mandate/compile` (Oct 16)

Request: `{ "text": "Never let checking drop below $200..." }` → `{ "policy": {...}, "summary": [...], "warnings": [] }` (not saved yet: show it to the user for review).

🛠 `POST /api/personas/:personaId/mandate/sign` (Oct 16)

Request: `{ "naturalLanguage": "...", "policy": {...}, "pin": "1111" }` → the saved mandate (new `version`, `signedBy`).

Documents

🛠 `POST /api/personas/:personaId/documents` (Oct 17)

`multipart/form-data` with a `file` field (PDF, max 5 MB).

```
{
  "billId": "bill_doc_7",
  "extracted": { "payee": "CityPower", "amountCents": 18000, "dueDate": "2026-10-20",
"accountNumber": "CP-88213" },
  "untrusted": true,
  "warnings": ["This document contains instructions addressed to an AI assistant. They were
ignored."]
}
```

Show `warnings` prominently (red banner). This is the injection demo.

Audit & on-chain

🛠 `GET /api/audit` (Oct 14)

`?personaId=daniel&limit=100`

```
[
  {
    "seq": 42,
    "ts": "2026-10-12T09:15:02.000Z",
    "eventType": "action_denied",
    "actor": { "type": "agent", "personaId": "daniel" },
    "summary": "Blocked transfer of $500.00 to new payee (source: untrusted document)",
    "hash": "9f1c…e2",
    "prevHash": "47aa…b1"
  }
]
```

🛠 `GET /api/audit/verify` (Oct 14)

```
{ "valid": true, "entries": 312, "brokenAt": null }
```

🛠 `GET /api/anchors` (Oct 17, stretch)

```
[
  { "date": "2026-10-17", "merkleRoot": "0x5be1…", "chain": "base-sepolia", "txHash":
"0xa41f…", "explorerUrl": "https://sepolia.basescan.org/tx/0xa41f…" }
]
```

Screens → endpoints

Screen	Uses
Sign-in	`auth/demo-accounts`, `auth/login`, `auth/me`
Persona switcher ("switch demo account")	`auth/logout` + `auth/login`
Dashboard	`accounts`, `budget`, `forecast`, `subscriptions`, `bills`, `wishes`, `transactions?limit=10`
Wishes list	`wishes`, `pay-cycle`
New / edit wish	`wishes/preview` (live), `POST wishes`, `PATCH /wishes/:id`
Wish detail	`GET /wishes/:id`, `POST /wishes/:id/contribute`, `DELETE /wishes/:id`
Chat	`POST chat` (SSE)
Approvals	`approvals`, `POST /actions/:id/decision`, `timeline` (SSE); show `wishImpact` on each card
Action timeline	`actions`, `timeline` (SSE), `POST agent/run` (payday button)
Rules (mandate) editor	`mandate`, `mandate/compile`, `mandate/sign`
Bill upload	`POST documents`
Audit log	`audit`, `audit/verify`, `anchors`
Header	`killswitch` (GET + POST)

Changelog

- **v3.1 (Oct 13):** budget, forecast, subscriptions, bills and pay-cycle are **live** (examples are real output). `payday` is now a display label (`"Fridays"`); subscriptions gained `accountId`, `lastCharged`, `nextCharge`; bills gained `accountId`; `avgSurplusPerCycleCents` now means left over after *all* normal spending.
- **v3 (Oct 13):** demo auth: `/api/auth/*`, session cookie, `401`/`403` on persona-scoped routes, `pin` on approve / sign / agent-on, `x-admin-key` on reset, `actor` on audit entries. Takes effect **Oct 15**; until then everything stays open.
- **v2.1 (Oct 12):** personas, accounts, transactions and admin reset are live. IDs are stable across resets (`acc_maya_chk`, `tx_maya_0001`…).
- **v2 (Oct 12):** added Wishes (`/wishes…`, `pay-cycle`, `wishImpact` on actions), `POST /api/admin/reset`, data-reset and cold-start notes; action type `create_goal` replaced by `wish_contribution`.

- **v1 (Oct 12):** first version.